

Axiom Nexus, LLC — Data Retention and Disposal Policy

Effective date: April 23, 2026 **Owner:** Clarence Fuqua, Founder, Axiom Nexus, LLC

Contact: security@axiomprotocol.app (monitored group address) · info@axiomprotocol.app (general) **Review cadence:** Annually, or upon any material change to the data scope, third-party processor list, or applicable law. **Status:** Canonical. This document is the source of truth for retention and disposal of consumer and operational data on the Axiom Protocol platform.

This policy is rendered verbatim at `/disclosure/data-retention-policy`. The file at `documents/policies/data-retention-policy.md` is the canonical text. Any change to the policy must change this file; the disclosure page reads it at request time so the document and the page can never drift.

This policy operationalises §8 of the [Privacy Policy](#) and §8 of the [Information Security Policy](#). Where they overlap, this document is the authoritative specification for retention windows, disposal mechanisms, and the data subject deletion path.

1. Purpose and scope

This policy defines, for every category of data the Platform handles:

- The **retention window** — how long the data is kept.
- The **legal or operational basis** — why it is kept that long.
- The **disposal mechanism** — how it is removed when retention expires or when a data subject requests deletion.
- The **storage tier** — where it lives while it is retained.

It applies to all production data stores (Neon Postgres, MongoDB Atlas analytics, Google Cloud Storage / Storacha object storage), all server logs, and all backups derived from those stores.

2. Data categories and retention windows

The Platform classifies retained data into the following categories. The window is the **maximum** retention; data may be deleted earlier upon a valid data-subject deletion request, subject to the legal-hold exceptions in §6.

Category	Storage tier	Retention window	Basis	Disposal mechanism
Plaid <code>access_token</code> , <code>item_id</code>	Postgres <code>cap_*</code> tables, application-layer envelope encrypted	Active life of the linked relationship; revoked through Plaid <code>/item/remove</code> within 30 days of deletion request, account disconnection, or end of the funding relationship	Operating Plaid Auth + Balance integration on user instruction	Call Plaid <code>/item/remove</code> ; row-level delete in Postgres; envelope key for the encrypted token rotated out of active use
Bank account number, routing number (from Plaid Auth)	Postgres <code>cap_*</code> tables, encrypted at rest	Until the resulting ACH transfer reaches a terminal state (<code>SETTLED</code> , <code>FAILED</code> , <code>RETURNED</code>); then removed from active store	Originating and reconciling the ACH debit the user authorised	Row-level delete in Postgres; masked reference (last four only) retained on the audit trail per §3
Account balances (from Plaid Balance)	Postgres <code>cap_*</code> tables, ephemeral	Not persisted beyond the request that needed them, except as a balance-check decision recorded as an audit event with the value redacted to a sufficiency flag	Confirming the requested debit is feasible before submission	No persistent storage of the balance value itself
Wallet address, on-chain transaction history	Postgres + on-chain	While the user maintains a relationship with the Platform; on-chain data is publicly visible regardless of the Platform's involvement	Operating the Platform features the user requested	Row-level delete in Postgres; on-chain data cannot be removed (disclosed in the Privacy Policy)
Audit events (<code>cap_audit_events</code>)	Postgres, append-only	Seven years (84 months) from event timestamp; then automatically purged	Bank Secrecy Act and applicable financial-records retention	Scheduled purge of rows older than the window; cryptographic chain of audit events preserved up to the purge boundary

Category	Storage tier	Retention window	Basis	Disposal mechanism
Server logs (request, response status, IP, user-agent)	Replit-managed log store	Thirty days rolling	Security and abuse prevention	Automatic rotation by the platform
Reserve and solvency snapshots	Postgres	Seven years	Disclosure, regulatory record	Scheduled purge of rows older than the window
Operator action records (cap_admin_actions)	Postgres	Seven years	Operator accountability, dual-actor record	Scheduled purge of rows older than the window
Email contents (transactional, via Resend)	Resend retention per their terms	Per Resend's published retention	Operating notifications the user requested	Resend handles disposal under their published policy
Analytics events (MongoDB)	MongoDB Atlas	Thirteen months rolling, aggregated and de-identified after thirty days	Operating, securing, and improving the Platform	Time-to-live index on the events collection
Object storage (uploaded documents, e.g. signed subscription agreements)	Google Cloud Storage / Storacha	While the underlying contractual relationship is active, plus seven years for records subject to financial-records retention	Operating the relationship the user established; tax and securities record-keeping	Object-level delete; tombstone written to the audit trail

3. Audit-trail records of deleted data

When a record is deleted from the active store under §2, the corresponding audit event is **not** deleted on the same schedule. The audit event records that the action took place, the actor, and the timestamp, with the substantive payload reduced to:

- A masked reference (e.g. last four digits of an account number) where a financial-records obligation requires it.
- A categorical flag (e.g. "balance sufficient" / "balance insufficient") where the underlying value is not required.
- The hash of any document whose retention has expired, where retention of the hash supports later integrity verification without retaining the content.

This preserves the audit trail required by financial-records law without retaining the underlying personal or financial data beyond its retention window.

4. Data subject request SLA

The Platform processes data subject requests (access, correction, deletion, withdrawal of consent) within **thirty days** of receipt at info@axiomprotocol.app. The thirty-day SLA covers:

1. Acknowledgement to the requester within five business days.
2. Authentication of the requester (typically by signature from the wallet associated with the account).
3. Execution of the request:
 - **Deletion of Plaid-derived data** is performed by calling Plaid `/item/remove` and deleting the corresponding rows from the active store.
 - **Deletion of other personal data** is performed by row-level delete from Postgres and object-level delete from object storage, subject to the legal-hold exceptions in §6.
 - **Access** is fulfilled by producing a structured export of the records held, excluding records to which the requester has no entitlement.
 - **Correction** is fulfilled by updating the record and writing an audit event recording the prior value.
4. Confirmation to the requester that the request has been completed.

If a request cannot be completed within thirty days (for example, because of a legal hold), the requester is informed in writing of the reason and the expected disposition.

5. Disposal mechanisms by storage tier

- **Postgres (Neon).** Row-level `DELETE` against the active store. Rows older than the retention window are removed by a scheduled job that runs against `cap_audit_events`, `cap_admin_actions`, and other long-retention tables. Logical deletes are not used for retention disposal; the row is physically removed. Backups inherit the retention window of the live row through Neon's point-in-time backup posture.
- **MongoDB Atlas (analytics).** Time-to-live indexes enforce the thirteen-month rolling window. Aggregation jobs strip personal identifiers after thirty days.
- **Object storage (GCS, Storacha).** Object-level `DELETE` removes the active object. A tombstone audit event records the disposal. Where a versioned bucket retains prior generations, the prior generations are removed on the same schedule.
- **Server logs.** Automatic rotation by the hosting platform; no manual intervention required for routine retention.
- **Application-layer envelope-encrypted tokens** (Plaid `access_token`). The encrypted blob is removed from Postgres on the same schedule as the parent row; the envelope key for tokens past their retention window is rotated out of active use so that a future copy of the historical encrypted blob cannot be decrypted.

6. Legal holds and retention extensions

A category-specific retention window is overridden in either of the following cases:

1. **Legal hold.** A documented legal, regulatory, or contractual obligation (subpoena, regulatory inquiry, ongoing litigation, audit) requires the data to be retained beyond the window. The hold is recorded by the Information Security Lead with the basis and the expected duration. The hold is released as soon as the obligation is satisfied.
2. **Active dispute.** A reconciliation dispute, chargeback, or fraud investigation involving the underlying transaction. Retention extends until the dispute reaches a terminal state.

A legal hold suspends the retention window for the affected records but does not extend it for unaffected records.

7. Plaid `/item/remove` revocation path

The Platform exposes a user-facing control to disconnect any linked bank account. Activating that control:

1. Calls Plaid `/item/remove` with the corresponding `item_id`, terminating Plaid's authority to access the underlying institution on the user's behalf.
2. Marks the corresponding row in the active store for deletion.
3. Removes the row, the encrypted `access_token`, and any cached account-and-routing numbers from the active store within thirty days, subject to the legal-hold exceptions in §6.
4. Writes an audit event recording the disconnection, with the substantive payload reduced per §3.

The same path is invoked when a deletion request is received under §4 and when the funding relationship ends.

8. Annual review

This policy is reviewed at least annually by the Information Security Lead. Changes are recorded by editing this file in source control; the rendered disclosure page reflects the current text on every load. The annual review verifies that:

- Each retention window remains aligned with the underlying legal or operational basis.
- Each disposal mechanism is functioning (verified by sampling).
- The data subject request SLA is being met (verified against the request register).
- The processor inventory in the Information Security Policy and the Privacy Policy is consistent with the retention windows in §2.

Axiom Nexus, LLC operates the Axiom Protocol platform. Privacy and access requests should be sent to info@axiomprotocol.app. Security disclosures should be sent to security@axiomprotocol.app (monitored group address).